

UNIVERSIDAD PRIVADA DEL NORTE

Escuela de Posgrado

Maestría

TRABAJO FINAL GRUPAL

Curso: Framework de Ciberseguridad

Propuesta de Implementación de un Programa de Ciberseguridad Integrado bajo ISO/IEC 27110 y NIST CSF 2.0

Guía del Estudiante

INTEGRANTES:

Chavez Rodriguez, Victor Ivan
Esteven Cristopher Alfaro Cotrina
Ttito Saya, Alexander
Zavaleta García, Jorge Alberto

DOCENTE:

Juan Altuna Velasquez

2026

Modalidad: Virtual Síncrono

Lima — Perú

ÍNDICE

1. Descripción del Escenario Organizacional	3
1.1. Identificación y Clasificación de la Organización	3
1.2. Tamaño y Alcance de la Operación	3
1.3. Modelo de Negocio y Propuesta de Valor	3
1.4. Procesos Críticos Digitales.....	3
1.5. Infraestructura Tecnológica.....	3
1.6. Marco Regulatorio y Estándares de Cumplimiento	4
1.7. Mapa de Partes Interesadas (Stakeholders).....	4
1.8. Frase-Diagnóstico Preliminar.....	4
2. Diagnóstico del Estado Actual.....	5
2.1. Current Profile NIST CSF 2.0 de la Organización	5
a) Función: GOVERN (Gobernar).....	5
b) Función: IDENTIFY (Identificar)	5
c) Función: PROTECT (Proteger)	5
d) Función: DETECT (Detectar).....	6
e) Función: RESPOND (Responder)	6
f) Función: RECOVER (Recuperar).....	6
2.2. Análisis Narrativo de las Brechas Más Críticas	6
a) Ausencia de Gobernanza y Liderazgo en Ciberseguridad (Función: GOVERN).....	6
b) Inexistencia de Planes de Respuesta ante Incidentes (Función: RESPOND)	7
3. Justificación Estratégica del Framework	7
3.1. Análisis de Factores Organizacionales	7
3.2. Selección y Justificación de la Estrategia	8
3.3. Descarte de Estrategias Alternativas.....	8
3.4. Principal Reto y Riesgo Organizacional de la Estrategia Elegida.....	9
4. Propuesta del Programa de Ciberseguridad	9
4.1. Target Profile (Estado Objetivo a 18 meses)	9
4.2. Análisis de Brechas Priorizado	10
4.3. Roadmap en 3 Horizontes	11
4.3.1. Horizonte 1 — Quick Wins (0 a 3 meses).....	11
4.3.2. Horizonte 2 — Consolidación (3 a 12 meses).....	11
4.3.3. Horizonte 3 — Transformación (12 a 36 meses)	11
4.4. Arquitectura del Modelo Integrado de 3 Capas	12
5. ANEXOS.....	13

1. Descripción del Escenario Organizacional

1.1. Identificación y Clasificación de la Organización

Grupo Palermo es una organización de capital privado perteneciente al sector de Tecnología, específicamente en el subsector de Servicios de Arrendamiento Tecnológico (Leasing Operativo). Con 30 años de trayectoria en el mercado peruano, la empresa ha evolucionado desde sus orígenes en Trujillo hasta consolidar una presencia a nivel nacional con sedes estratégicas en Lima, Chiclayo, Huancayo y Piura, además de contar con soporte técnico desplegado en todos los departamentos del país.

1.2. Tamaño y Alcance de la Operación

La organización cuenta con una estructura humana de aproximadamente 100 empleados y gestiona una cartera activa de 300 clientes, que abarcan tanto instituciones del Estado como empresas del sector privado de alta relevancia. En términos de volumen operativo, la compañía reporta una facturación anual de \$4 millones de dólares, lo que refleja una operación robusta y una gestión constante de activos tecnológicos críticos.

1.3. Modelo de Negocio y Propuesta de Valor

El modelo de negocio de Grupo Palermo se centra en el arrendamiento operativo de infraestructura tecnológica integral. Su oferta incluye equipos de impresión, dispositivos de usuario final (client), infraestructura de centros de datos, networking, sistemas de videovigilancia (CCTV), soluciones audiovisuales (AV) y gestión documental. La competitividad de la empresa se sustenta en sus alianzas estratégicas con socios tecnológicos globales como IBM, Dell, Cisco, Lenovo, HP, Ricoh y Zebra, actuando como un eslabón crítico en la cadena de suministro de TI para sus clientes.

1.4. Procesos Críticos Digitales

La continuidad del negocio depende estrictamente de la disponibilidad e integridad de tres procesos digitales fundamentales:

- **Gestión de Mantenimiento (Fieldservice):** Ejecución de mantenimientos preventivos y correctivos gestionados a través de Salesforce, esencial para el cumplimiento de los SLA con los clientes.
- **Monitoreo de Infraestructura (Nube Print):** Supervisión en tiempo real de la operatividad de los equipos desplegados, permitiendo una respuesta proactiva ante incidentes.
- **Gestión de Proyectos:** Centralización de la documentación, flujos de trabajo y colaboración interna mediante la plataforma SharePoint.

1.5. Infraestructura Tecnológica

La infraestructura de la organización presenta un esquema de Cloud Nativo, apalancándose en proveedores de servicios en la nube de primer nivel para garantizar escalabilidad y resiliencia:

- **Amazon Web Services (AWS):** Soporta las operaciones críticas de los sistemas Salesforce y Nube Print.
- **Microsoft Azure:** Aloja el entorno de colaboración y gestión documental de SharePoint.

Esta dependencia de proveedores críticos de nube subraya la importancia de la seguridad en entornos compartidos y la gestión de identidades.

1.6. Marco Regulatorio y Estándares de Cumplimiento

Debido a su naturaleza operativa y su relación contractual con el sector público, la organización se rige por el siguiente marco legal y normativo:

- **Ley N° 29733 (Ley de Protección de Datos Personales):** Obligatoria para garantizar la privacidad de la información de clientes y empleados.
- **DL N° 1412 y DS N° 029-2021-PCM:** Normativas de Gobierno y Seguridad Digital que rigen sus compromisos contractuales con el Estado Peruano.
- **Referentes Técnicos:** La empresa utiliza como guía la NTP-ISO/IEC 27001 para la estructuración de su sistema de gestión, complementando sus certificaciones vigentes en Calidad (ISO 9001), Medio Ambiente (ISO 14001) y Antisoborno (ISO 37001).

1.7. Mapa de Partes Interesadas (Stakeholders)

A continuación, se visualizan los actores clave que influyen y son influenciados por la estrategia de ciberseguridad de la organización:

- **Internos:** Directorio (toma de decisiones estratégicas), Gerencia General (ejecución de presupuesto), y el equipo de Operaciones/TI.
- **Externos:** Reguladores (Autoridad Nacional de Protección de Datos Personales, PCM), Clientes (Entidades del Estado y Sector Privado) y Proveedores Críticos (AWS, Azure, Cisco, HP).

1.8. Frase-Diagnóstico Preliminar

"Grupo Palermo presenta un nivel de madurez en ciberseguridad en etapa de transición; aunque posee una infraestructura moderna basada en la nube y un cumplimiento normativo impulsado por exigencias contractuales, requiere fortalecer la resiliencia proactiva de sus procesos críticos ante la alta dependencia de terceros y la dispersión geográfica de sus activos."

2. Diagnóstico del Estado Actual

2.1. Current Profile NIST CSF 2.0 de la Organización

Para evaluar el estado actual de madurez en ciberseguridad de Grupo Palermo, se ha empleado el marco de referencia NIST Cybersecurity Framework (CSF) 2.0. La evaluación se ha realizado sobre una escala de madurez de 0 a 4 para las seis funciones principales del framework.

Para este diagnóstico preliminar, el equipo ha seleccionado y priorizado una subcategoría crítica por cada función, sustentando la calificación con evidencia recolectada a través de revisión documental, entrevistas internas y análisis de la infraestructura técnica.

a) Función: GOVERN (Gobernar)

- **Subcategoría Evaluada:** GV.RM-01 (Gestión de Riesgos).
- **Nivel de Madurez:** 0
- **Evidencia de sustento:** Las entrevistas con la gerencia y la revisión documental revelan que la gestión de riesgos cibernéticos no ha sido considerada formalmente en la organización. No existen políticas, procedimientos ni documentos formales para la identificación, análisis o tratamiento de riesgos. Asimismo, no hay evidencia de participación del Directorio en estas decisiones.
- **Brecha Principal:** Inexistencia absoluta de un marco formal de gestión de riesgos. No se ha definido el apetito de riesgo de la empresa ni existe involucramiento de la alta dirección.

b) Función: IDENTIFY (Identificar)

- **Subcategoría Evaluada:** ID.AM-01 (Gestión de Activos).
- **Nivel de Madurez:** 2
- **Evidencia de sustento:** La revisión de los repositorios internos demuestra que se dispone de un inventario de activos documentado en SharePoint, el cual cuenta con una clasificación por criticidad y responsables asignados.
- **Brecha Principal:** Aunque existe el inventario, no se cuenta con herramientas automatizadas que permitan extraer métricas de control o mantener una actualización dinámica.

c) Función: PROTECT (Proteger)

- **Subcategoría Evaluada:** PR.AA-03 (Autenticación y Control de Acceso).
- **Nivel de Madurez:** 2
- **Evidencia de sustento:** Las pruebas técnicas y revisión de configuraciones confirman la implementación de Microsoft Authenticator como mecanismo MFA (Autenticación Multifactor) para entornos críticos. Este control está respaldado por procedimientos formales de instalación y una matriz de responsabilidades para su mantenimiento.
- **Brecha Principal:** Incapacidad tecnológica para medir la adopción real. No existen métricas sobre la cantidad de usuarios que usan MFA activamente, ni registros de accesos acertados o denegados en periodos de tiempo determinados.

d) Función: DETECT (Detectar)

- **Subcategoría Evaluada:** DE.CM-01 (Monitoreo Continuo).
- **Nivel de Madurez:** 2
- **Evidencia de sustento:** Se evidenció documentación de procedimientos de instalación, configuración y mantenimiento de equipos Firewall perimetrales con capacidades Anti-DDoS, los cuales identifican ataques de manera automática.
- **Brecha Principal:** Falta de un monitoreo centralizado (ej. SIEM). No existe correlación de eventos, indicadores de compromiso, ni visibilidad centralizada de las amenazas detectadas en los distintos nodos de la red.

e) Función: RESPOND (Responder)

- **Subcategoría Evaluada:** RS.MA-01 (Gestión de Incidentes).
- **Nivel de Madurez:** 1
- **Evidencia de sustento:** Las entrevistas al equipo de TI y la revisión de registros (tickets) confirman que la gestión de incidentes se realiza de manera puramente reactiva. No existen procedimientos formales aprobados, registros históricos estructurados, ni roles definidos para la respuesta ante vulneraciones.
- **Brecha Principal:** Carencia total de documentación operativa, Playbooks de respuesta y designación de responsables formales ante incidentes de ciberseguridad.

f) Función: RECOVER (Recuperar)

- **Subcategoría Evaluada:** RC.RP-01 (Planificación de la Recuperación).
- **Nivel de Madurez:** 2
- **Evidencia de sustento:** La revisión técnica de la infraestructura confirma que se cuenta con una solución de respaldo Veeam Backup & Replication bajo un modelo on-premise, centralizando las copias en un servidor secundario dedicado. El proceso se rige por una política básica de retención.
- **Brecha Principal:** Alta dependencia de procesos manuales. Se tiene la percepción de que la recuperación es posible, pero el tiempo de retorno a la operación (RTO) es peligrosamente alto debido a la falta de orquestación, automatización del ciclo de vida y ausencia de pruebas de integridad programadas.

2.2. Análisis Narrativo de las Brechas Más Críticas

Tras la evaluación de las seis funciones del framework NIST CSF 2.0, el equipo ha priorizado las dos brechas más críticas que representan el mayor nivel de exposición y riesgo para la continuidad y legalidad de las operaciones de Grupo Palermo. Estas se detallan a continuación:

a) Ausencia de Gobernanza y Liderazgo en Ciberseguridad (Función: GOVERN)

Esta es la brecha más crítica del escenario actual porque representa una falla estructural de origen. Al no existir la participación del Directorio ni la definición de un apetito de riesgo corporativo (Nivel 0), la ciberseguridad está siendo gestionada erróneamente como un gasto operativo (OPEX) del área de TI, y no como una prioridad estratégica del negocio.

La gravedad de esta brecha radica en que sus efectos caen en cascada, al no haber apoyo directivo, se impide la asignación de presupuesto necesario para cerrar brechas técnicas (como la falta de un SIEM en la función Detectar). Más crítico aún, esta omisión deja a la alta gerencia legalmente expuesta ante posibles incumplimientos y sanciones derivadas de la Ley N° 29733 (Ley de Protección de Datos Personales), especialmente considerando los contratos vigentes de la empresa con el sector público.

b) Inexistencia de Planes de Respuesta ante Incidentes (Función: RESPOND)

Se ha priorizado esta brecha por su altísimo impacto operativo. Al contar con una gestión reactiva carente de documentación y Playbooks (Nivel 1), Grupo Palermo depende exclusivamente del conocimiento empírico de técnicos específicos, un antipatrón conocido como "heroísmo técnico".

Ante la materialización de un ciberataque real y de alto impacto (por ejemplo, un secuestro de datos por Ransomware), la falta de roles definidos obligará a la organización a improvisar. Esta improvisación aumenta drásticamente el tiempo de interrupción de los servicios críticos, dispara los costos de recuperación y eleva la probabilidad de cometer errores humanos bajo presión que terminen agravando el alcance del incidente inicial.

3. Justificación Estratégica del Framework

3.1. Análisis de Factores Organizacionales

Para determinar la estrategia de integración de frameworks más adecuada para Grupo Palermo, se ha realizado un análisis exhaustivo de cinco factores organizacionales clave. Este diagnóstico permite alinear las necesidades de ciberseguridad con la realidad operativa y comercial de la empresa:

- **F1 — Tamaño y madurez del equipo de ciberseguridad:** La organización cuenta únicamente con un equipo de soporte conformado por cuatro (4) asistentes de TI. Este personal necesita desarrollar u optimizar su capacidad operativa para afrontar ataques cibernéticos, lo que exige un marco de trabajo que los guíe sin sobrepasar su ancho de banda operativo. *(Inclinación: E2)*
- **F2 — Estado del SGSI y presión de certificación:** Actualmente, la empresa opera en la informalidad normativa; no existe un SGSI basado en ISO 27001, las políticas son empíricas y no hay un ciclo de mejora continua. Sin embargo, existe una fuerte presión externa (clientes del sector público y privado) e interna (área comercial) para obtener certificaciones. El programa debe priorizar la creación de políticas críticas, como la Respuesta a Incidentes, para mitigar el riesgo operativo y comercial derivado de una seguridad reactiva y no auditable. *(Inclinación: E2)*
- **F3 — Exposición regulatoria y contractual:** Grupo Palermo está en la obligación legal de cumplir con la Ley N° 29733 (Ley de Protección de Datos Personales). El programa de ciberseguridad debe garantizar la trazabilidad, confidencialidad y el monitoreo efectivo de los datos para evitar sanciones por parte de la Autoridad Nacional de Protección de Datos

Personales (ANPD), estableciendo controles auditables y responsabilidades claras.
(Inclinación: E2)

- **F4 — Cultura organizacional hacia el riesgo:** Como aspecto positivo, existe conciencia y visibilidad de los riesgos cibernéticos dentro de la organización. Esta ausencia de resistencia al cambio cultural facilita enormemente la adopción de nuevos controles y políticas.
(Inclinación: E2)
- **F5 — Horizonte temporal y recursos disponibles:** Este es el factor más restrictivo. La empresa opera con recursos limitados (tanto en presupuesto como en personal). Actualmente, no hay presupuesto asignado para contratar personal exclusivo de ciberseguridad, ya que el área comercial absorbe la mayor parte del capital disponible. Se requiere, por tanto, una estrategia simple, de rápida implementación y de bajo costo operativo que priorice controles críticos.
(Inclinación: E2)

3.2. Selección y Justificación de la Estrategia

Con base en el análisis previo, el equipo ha determinado que la vía de acción óptima es la Estrategia 2 (E2) — ISO 27001 como rector con NIST CSF como complemento.

Bajo este modelo, el SGSI mantendrá a la norma ISO 27001 como su columna vertebral para establecer el gobierno, las políticas formales y responder a la presión de certificación, mientras que NIST CSF 2.0 se utilizará operativamente para enriquecer el análisis de riesgos, facilitar la comunicación técnica con el directorio y planificar la mejora continua de las capacidades defensivas.

¿Por qué esta estrategia?

El peso fundamental de esta decisión recae en la intersección de dos factores críticos: la restricción de Recursos (F5) y la necesidad urgente de formalizar un SGSI (F2). Mientras que la limitación económica y de personal nos obliga a ser pragmáticos y moderados en la implementación, la necesidad comercial y regulatoria de contar con un sistema de gestión nos impide permanecer en la informalidad actual. La Estrategia E2 representa el equilibrio perfecto: proporciona la estructura auditable de ISO 27001 que el área comercial exige, complementada con el pragmatismo táctico de NIST CSF que los cuatro asistentes de TI pueden adoptar sin colapsar.

3.3. Descarte de Estrategias Alternativas

Para sustentar sólidamente la elección de la Estrategia E2, es imperativo justificar el descarte de las otras dos alternativas para este escenario organizacional específico:

- **Rechazo de la Estrategia 1 (Coexistencia paralela):** Se descarta tajantemente porque la implementación de dos frameworks en paralelo demanda un consumo excesivo de recursos operativos que Grupo Palermo no posee. Además, incurre en una incoherencia estructural: intentar ejecutar NIST CSF en paralelo sin contar con un SGSI base consolidado compromete la estabilidad del proyecto. La actual ausencia de capacidad técnica y administrativa hace insostenible mantener dos sistemas de gestión de forma aislada y simultánea.

- **Rechazo de la Estrategia 3 (Convergencia hacia un SGSI-C híbrido):** Se descarta por su alta complejidad de convergencia. La Estrategia 3 exige alinear armónicamente tres marcos normativos (ISO 27001, NIST CSF e ISO/IEC 27110). Lograr este nivel de madurez demanda una fuerte inversión en consultoría especializada, auditorías complejas y personal dedicado a tiempo completo. Esto resulta financieramente inviable en un contexto donde el presupuesto corporativo está priorizado y absorbido casi en su totalidad por el área comercial.

3.4. Principal Reto y Riesgo Organizacional de la Estrategia Elegida

El principal desafío para el éxito de la Estrategia E2 no es de carácter tecnológico, sino político y de sostenibilidad operativa.

Al no disponer de presupuesto inmediato para nuevas contrataciones, el reto radica en integrar estas nuevas tareas de gobernanza, documentación y respuesta a incidentes en la rutina diaria del equipo actual de infraestructura (asistentes de TI), sin afectar la operatividad del negocio (como los mantenimientos en Salesforce o Nube Print).

En consecuencia, el riesgo político latente es que la gerencia general y el área comercial perciban la ciberseguridad como un proceso "invisible" o un obstáculo burocrático, sin valorar su importancia hasta que se materialice un incidente grave. Para mitigar este riesgo, el equipo de TI deberá desplegar habilidades de persuasión y negociación, demostrando a la alta dirección que la implementación del SGSI requiere ineludiblemente una redistribución de recursos, asignación de tiempo específico y, a mediano plazo, la ampliación del personal para garantizar la sostenibilidad comercial y legal de Grupo Palermo.

4. Propuesta del Programa de Ciberseguridad

Este componente constituye el núcleo técnico de la propuesta. Su objetivo es establecer la hoja de ruta estratégica y operativa que guiará a la organización desde su estado actual hacia una postura de ciberseguridad resiliente, auditable y alineada con los requerimientos comerciales y legales del Estado peruano.

4.1. Target Profile (Estado Objetivo a 18 meses)

El perfil objetivo (*Target Profile*) define el nivel de madurez que la organización debe alcanzar en un plazo de 18 meses para las seis funciones del marco NIST CSF 2.0. Este diseño no busca la máxima calificación en todas las áreas de forma indiscriminada, sino un estado alcanzable y justificado por tres variables fundamentales: el apetito de riesgo de la dirección, el marco regulatorio exigido (Ley N° 29733, DL N° 1412) y las amenazas prevalentes en el sector tecnológico.

a) GOVERN (Gobernar) | Nivel Actual: 0 → Nivel Objetivo: 2

- **Justificación:** La organización opera con un alto riesgo regulatorio frente a la Ley N° 29733 y las normativas de la PCM (DL N° 1412, DS N° 029-2021-PCM, Directiva N° 004), las cuales exigen una gestión estructurada a los proveedores del Estado. Ante un apetito de riesgo moderado frente a impactos legales y operativos, es imperativo establecer una gobernanza

formal, gestión de riesgos y métricas de control para evitar accesos no autorizados y posibles sanciones por fuga de información.

b) IDENTIFY (Identificar) | Nivel Actual: 2 → Nivel Objetivo: 3

- **Justificación:** La trazabilidad estricta de los activos de información es un mandato legal. La ausencia de métricas actuales facilita puntos ciegos en la red. Con un apetito de riesgo moderado, se debe avanzar a un nivel gestionado (Nivel 3) que garantice la medición continua de los activos, sin requerir cambios arquitectónicos complejos.

c) PROTECT (Proteger) | Nivel Actual: 2 → Nivel Objetivo: 3

- **Justificación:** Las amenazas de compromiso de credenciales son críticas en operaciones en la nube. Dado el apetito de riesgo moderado frente a brechas, se requiere madurar los controles actuales (como el MFA), alineándolos con las buenas prácticas de la NTP-ISO/IEC 27001 y las exigencias de contratación pública.

d) DETECT (Detectar) | Nivel Actual: 2 → Nivel Objetivo: 3

- **Justificación:** Existe un bajo apetito de riesgo ante caídas operativas. Alcanzar el Nivel 3 permitirá implementar métricas y revisiones periódicas del monitoreo, independizando la detección de amenazas avanzadas del conocimiento empírico de los asistentes de TI y estandarizando la visibilidad en la infraestructura híbrida (AWS/Azure).

e) RESPOND (Responder) | Nivel Actual: 1 → Nivel Objetivo: 3

- **Justificación:** Frente a amenazas paralizantes como el *Ransomware*, el marco de seguridad digital del Estado exige capacidades formales de respuesta. Debido al muy bajo apetito de riesgo ante interrupciones contractuales, la organización debe pasar de la improvisación a un enfoque estructurado con *playbooks* definidos y métricas de contención.

f) RECOVER (Recuperar) | Nivel Actual: 2 → Nivel Objetivo: 3

- **Justificación:** La continuidad de los servicios de arrendamiento tecnológico no puede depender de procesos de recuperación sin pruebas. Con un apetito de riesgo moderado frente a la indisponibilidad, se exige fortalecer la capacidad de recuperación mediante medición y mejora continua de los respaldos.

4.2. Análisis de Brechas Priorizado

Para transicionar del *Current Profile* al *Target Profile*, se ha realizado un análisis de las brechas (*Gaps*) existentes. La priorización de estas brechas se ejecutó evaluando cuatro criterios estratégicos: la criticidad del activo expuesto, la probabilidad de explotación en los próximos 12 meses, el coste financiero del control mitigador y la velocidad de implementación.

El análisis revela que las seis brechas funcionales poseen una Prioridad Global Alta. Esto refleja el estado crítico de la organización en su fase inicial frente a obligaciones contractuales ineludibles. Destacan por su urgencia la función de **RESPOND** (Brecha de 2 niveles; costo medio, alta velocidad de corrección) y **GOVERN** (Brecha de 2 niveles; costo alto, pero fundamental para sostener el resto del programa).

4.3. Roadmap en 3 Horizontes

Para ejecutar el cierre de brechas de manera ordenada y respetando la restricción de recursos evaluada en el Componente 3, se propone un plan de implementación estructurado en cinco iniciativas distribuidas a lo largo de tres horizontes temporales:

4.3.1. Horizonte 1 — Quick Wins (0 a 3 meses)

Enfocado en victorias tempranas de bajo costo y alto impacto para proteger los accesos críticos y establecer la base documental.

- **QW-01:** Definición y aprobación de las políticas de seguridad alineadas a la Ley N° 29733, ISO 27001 y los lineamientos de la Directiva N° 004-2021-PCM/SEGDI
 - **Función NIST:** GOVERN
 - **Responsable:** CISO
- **QW-02:** Activación obligatoria de autenticación multifactor para accesos remotos y plataformas críticas (Salesforce, Nube Print y SharePoint en Azure/AWS)
 - **Función NIST:** PROTECT
 - **Responsable:** Asistente de TI

4.3.2. Horizonte 2 — Consolidación (3 a 12 meses)

Orientado a formalizar la resiliencia operativa y la visibilidad táctica, moviendo a la organización de una postura reactiva a una gestionada mediante métricas.

- **C-01:** Implementación de backups inmutables en Veeam y creación de Playbooks de respuesta ante incidentes para reducir el RTO operativo.
 - **Función NIST:** Recover
 - **Responsable:** Asistente de TI
- **C-02:** Despliegue de tableros de control para el monitoreo dinámico de activos y cumplimiento de seguridad, asegurando la trazabilidad exigida por ley.
 - **Función NIST:** Detect
 - **Responsable:** CISO

4.3.3. Horizonte 3 — Transformación (12 a 36 meses)

Enfocado en la madurez cultural, la medición continua y la preparación para certificaciones internacionales formales.

- **T-01:** Capacitación continua del personal en riesgos de ingeniería social y ejecución de una auditoría interna para validar la madurez del SGSI antes de la certificación formal.
 - **Función NIST:** GOVERN
 - **Responsable:** CISO

4.4. Arquitectura del Modelo Integrado de 3 Capas

Como cierre conceptual de la propuesta del programa de ciberseguridad para Grupo Palermo, se ha diseñado una arquitectura de gestión basada en un modelo integrado de tres capas (**Anexo I**). Esta estructura permite alinear las operaciones técnicas diarias con los objetivos estratégicos del negocio, garantizando que la ciberseguridad sea medible, auditable y comprensible para todos los niveles de la organización.

El modelo, fundamentado en la convergencia de marcos internacionales, se estructura de la siguiente manera:

- **Capa 1 — Nivel Estratégico (ISO/IEC 27110):** Actúa como la cúspide del modelo. Su propósito es traducir la complejidad técnica de la ciberseguridad a un lenguaje de negocio y gestión de riesgos. Esta capa facilita la comunicación efectiva de las cinco funciones básicas, permitiendo que la alta dirección comprenda la exposición real al riesgo y tome decisiones informadas sobre la asignación de recursos.
- **Capa 2 — Nivel Táctico y de Medición (NIST CSF 2.0):** Funciona como el motor analítico del programa. A través de la definición de perfiles (Current y Target), esta capa permite diagnosticar el estado de madurez, establecer objetivos trazables a 18 meses y estructurar el roadmap de iniciativas. Es el puente metodológico que conecta la visión estratégica con la ejecución operativa.
- **Capa 3 — Nivel Operativo y Normativo (ISO/IEC 27001):** Constituye la base auditable del sistema. Proporciona el marco riguroso para la implementación de controles, la redacción de políticas y la estandarización de procesos bajo un enfoque de mejora continua (SGSI). Esta capa es la que materializa el cumplimiento de las normativas peruanas (LeyN° 29733, DL 1412) y prepara a la organización para futuras certificaciones formales.

A continuación, se presenta la tabla resumen que detalla la interacción, responsabilidades y entregables de cada capa dentro del escenario organizacional de Grupo Palermo:

Aspecto	Capa 1 — ISO/IEC 27110 (Estratégica)	Capa 2 — NIST CSF 2.0 (Táctica)	Capa 3 — ISO/IEC 27001 (Operativa)
Aporte al programa	Traduce la ciberseguridad a un lenguaje estratégico y facilita la toma de decisiones.	Permite diagnosticar el estado actual, definir objetivos y planificar mejoras metodológicas.	Formaliza la gestión mediante políticas, controles y un enfoque auditable de mejora continua.
Usuario Principal	El Directorio y la Gerencia General.	Responsable de TI (o rol de CISO).	Equipo de Infraestructura y Operaciones (Asistentes de TI).
Entregables	Reporte de madurez, diagnóstico y plan	<i>Current Profile, Target Profile</i> , análisis de	Políticas de seguridad, matriz de controles,

	estratégico de mejora (Reporte Ejecutivo).	brechas y <i>Roadmap</i> de iniciativas.	auditorías y evidencia para certificación.
Cadencia de revisión	Revisión semestral o anual (Reporte ejecutivo de activos críticos y exposición al riesgo).	Seguimiento mensual (Avances del <i>roadmap</i> e indicadores de las funciones).	Revisión anual de políticas y seguimiento continuo del cumplimiento de controles.
Interacción con otras capas	Recibe información de NIST (Capa 2) y traduce los resultados técnicos para justificar decisiones.	Alimenta a ISO 27110 (Capa 1) con métricas y a ISO 27001 (Capa 3) con prioridades técnicas.	Implementa los controles definidos a partir del análisis de NIST (Capa 2) y requerimientos de la Capa 1.

5. ANEXOS

Anexo I

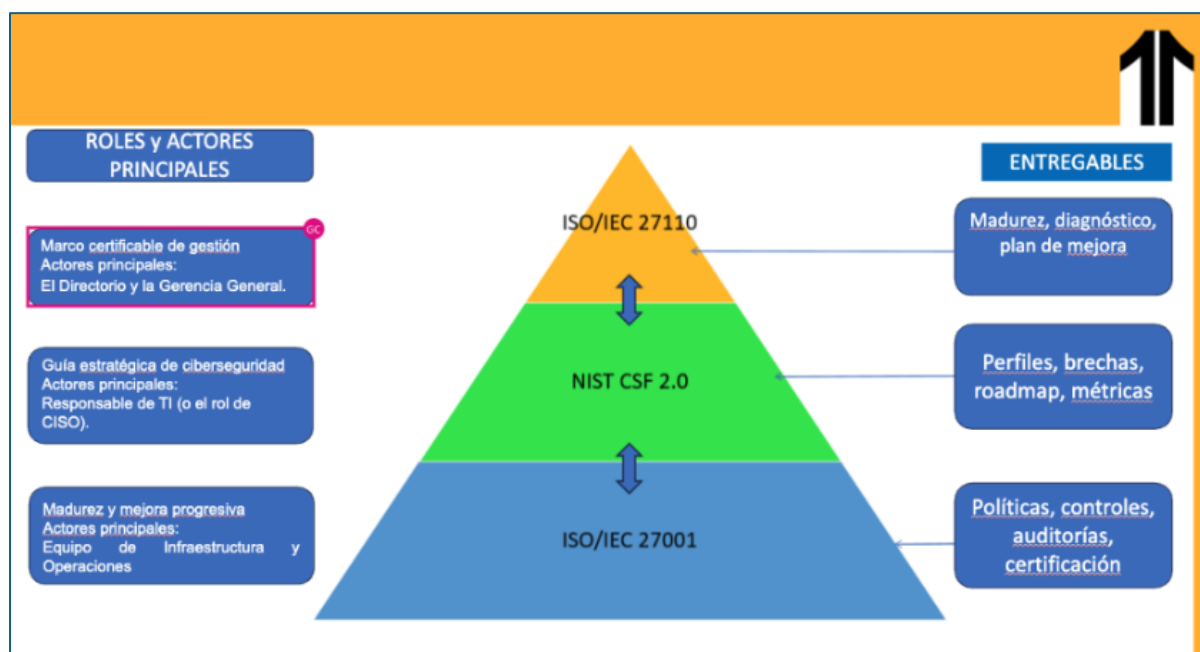


Figura 1. Arquitectura del modelo integrado de ciberseguridad en tres capas (ISO 27110, NIST CSF 2.0 e ISO 27001).